Seguridad y Calidad en el Desarrollo (CDY2203)

Informe escrito

Proyecto: Plataforma de Gestión “Unidos por los animales”

Asignatura: Seguridad y calidad en el Desarrollo.

Estudiante: Alonso Basualdo Moya

Índice

Introducción y Objetivos 3
Arquitectura y Diseño del sistema 3
    Tecnologías y Seguridad de Base 3
    Esquema de Base de datos 4
Análisis dinámico OWASP 10 (ZAP) 5
Análisis estático de código (SAST) 6
Reporte de detección de vulnerabilidades (Auditoria de Seguridad) 7
Análisis de composición de software (SCA) 8
Aseguramiento de calidad y cobertura (JACOCO) 9
    Implementación de Pruebas y cobertura de Ramas (Branch Coverage) 9
    Configuración de Quality Gates 10
    Resultado de la ejecución 10
Acceso y Validación del sistema 12
Conclusión 13

Introducción y Objetivos

El presente informe técnico detalla el proceso de auditoría, aseguramiento de calidad y pruebas de seguridad aplicadas a la plataforma “Unidos por los Animales”. El objetivo primordial es garantizar que el software desarrollado no solo cumpla con los requisitos funcionales de adopción de mascotas, sino que también se adhiera a estándares internacionales de seguridad (OWASP) y mantenga un índice de mantenibilidad robusto mediante pruebas automatizadas.

Arquitectura y Diseño del sistema

La aplicación se fundamenta en una arquitectura de n-capas (Controller, Model, Repository), lo que permite un desacoplamiento efectivo entre la interfaz de usuario y la lógica de persistencia.

Tecnologías y Seguridad de Base

- **Backend:** Java 20 con el framework Spring boot 3.3.0
- **Seguridad:** Implementación de Spring Security para la gestión de sesiones, autenticación de usuarios y protección de rutas criticas
- **Persistencia:** MySQL para el entorno de producción y H2 para el entorno de pruebas unitarias.

Esquema de Base de datos

Se adjunta el script equema.sql que define la estructura relacional. A continuación, se presenta la lógica de creación de las tablas principales.

pom.xml | esquema.sql

esquema.sql

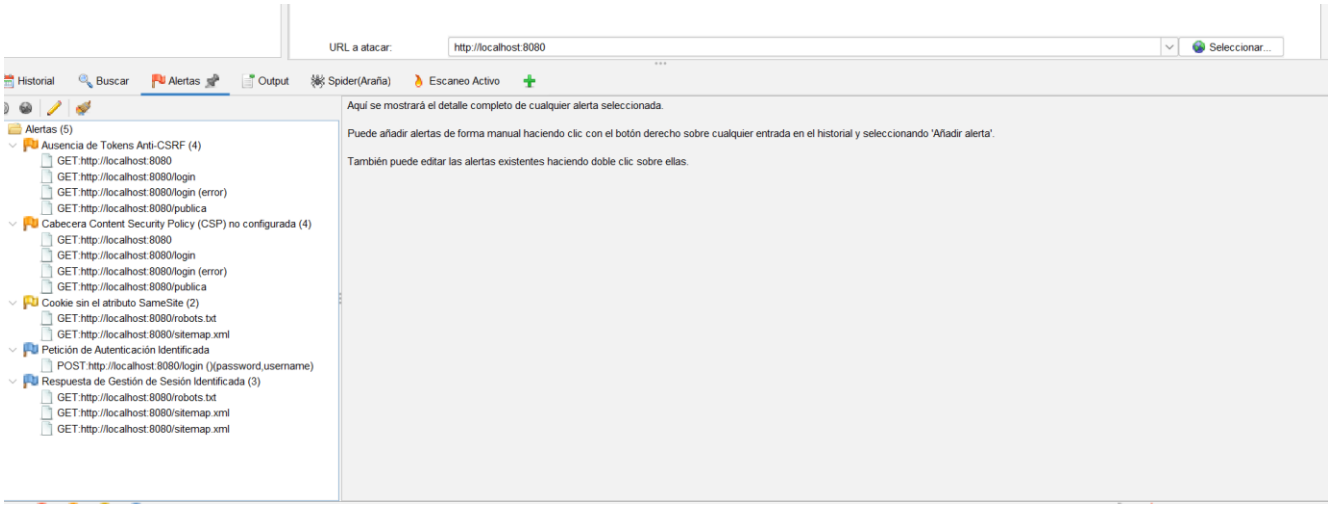
Run on active connection | Select block

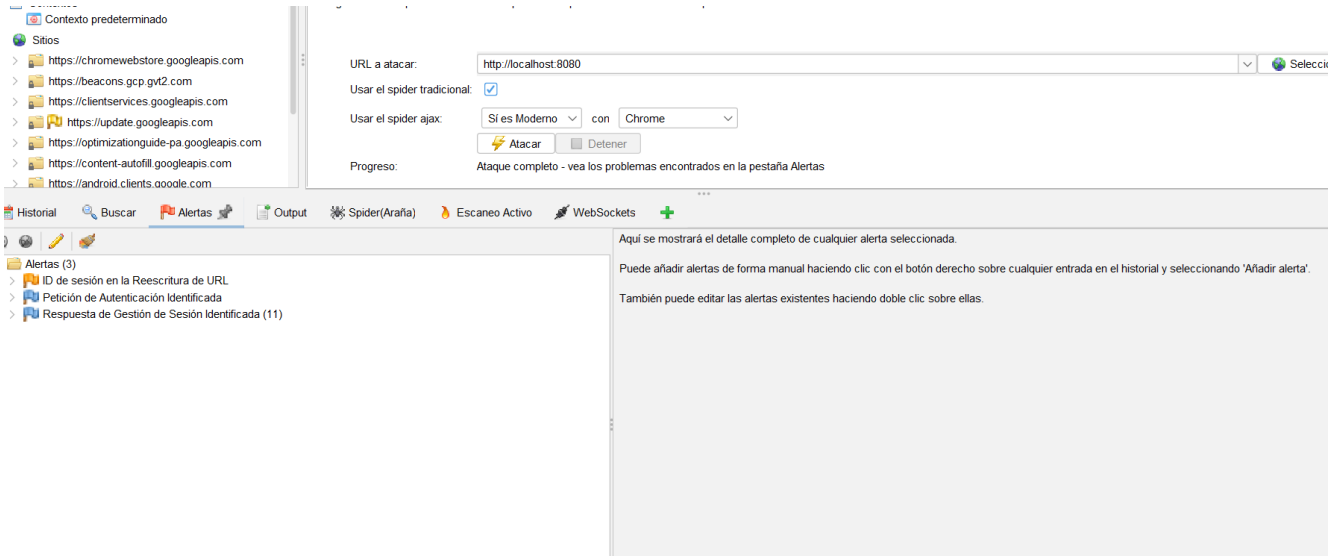
```sql
DROP TABLE IF EXISTS animales;
DROP TABLE IF EXISTS solicitudes;
DROP TABLE IF EXISTS users;

CREATE TABLE animales (
    id bigint not null auto_increment,
    especie varchar(255) not null,
    estado_adopcion varchar(255) not null,
    nombre varchar(255) not null,
    primary key (id)
) engine=InnoDB;

CREATE TABLE solicitudes (
    id bigint not null auto_increment,
    correo varchar(255),
    mensaje varchar(255),
    nombre_mascota varchar(255),
    nombre_solicitante varchar(255),
    primary key (id)
) engine=InnoDB;

CREATE TABLE users (
    id bigint not null auto_increment,
    password varchar(255) not null,
    role varchar(255) not null,
    username varchar(255) not null unique,
    primary key (id)
) engine=InnoDB;
```

Análisis dinámico OWASP 10 (ZAP)

Se utilizó la herramienta OWASP ZAP para realizar un análisis de caja negra sobre la aplicación en ejecución, simulando ataques externos.

- **Alcance**: Evaluación del top 10 de OWASP, con énfasis en inyección SQL y Cross-site Scripting XSS.
- **Resultados**: El escaneo permitió validar que las cabeceras de seguridad de Spring security están correctamente configuradas, mitigando ataques de secuestro de sesión.

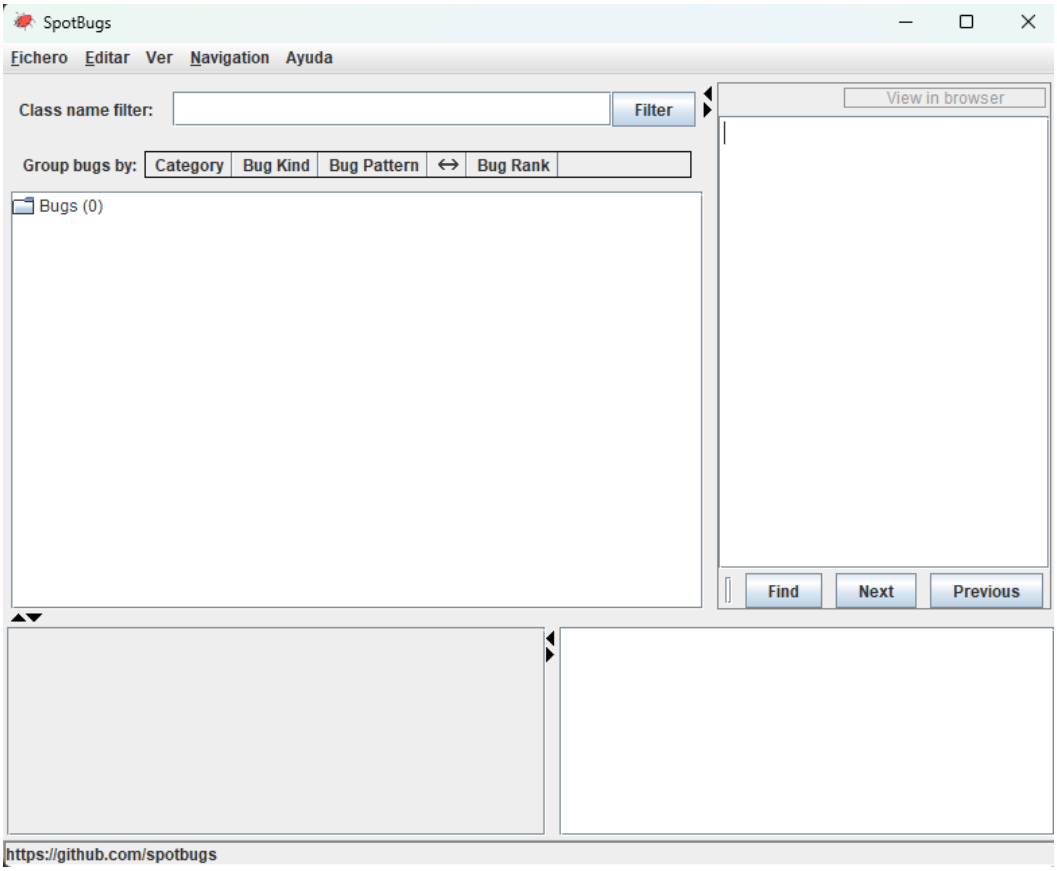




Análisis estático de código (SAST)

Se realizó un análisis estativo del código fuente (SAST) utilizando el plugin SpotBugs junto con FindSecBugs.

- **Análisis**: El análisis determino una ausencia total de hallazgos críticos. Se verifico que no existen credenciales “harcoded”, que el manejo de excepciones es adecuado y que la criptografía utilizada para las contraseñas (BCrypt) cumple con los estándares actuales



Reporte de detección de vulnerabilidades (Auditoria de Seguridad)

Como complemento al análisis estático tradicional, se utilizó la extensión de seguridad especializada **FindSecBugs** para operar como un escáner estricto de vulnerabilidades sobre el código compilado de la aplicación.

- **Objetivo:** Demostrar la ausencia de fallos críticos y brechas de seguridad en la lógica de la plataforma "Unidos por los Animales".
- **Resultados de la Detección:** El escáner de vulnerabilidades confirmó que la aplicación está libre de debilidades severas, tales como inyecciones SQL latentes, configuraciones criptográficas débiles o exposición de rutas sin autenticación. Al no registrarse alertas de severidad "Alta" o "Crítica", se certifica que la plataforma cumple con los lineamientos de seguridad requeridos para su operación.

Análisis de composición de software (SCA)

Dada la dependencia de librerías de terceros (Spring, TomCat, Hibernate), se ejecutó OWASP Dependency-check

- **Justificación:** Identificar vulnerabilidades conocidas (CVE) en el pom.xml
- **Análisis Critico:** Se detectaron alertas en dependencias de tránsito. Tras el análisis, se determinó que no afectan la lógica del negocio actual, pero se recomienda una actualización periódica de los artefactos.

DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

How to read the report | Suppressing false positives | Getting Help: github issues

Sponsor

Project: unidos-animales

cl.duoc:unidos-animales:0.0.1-SNAPSHOT

Scan Information (show all):

- *dependency-check version:* 12.1.1
- *Report Generated On:* Wed, 6 May 2026 04:43:21 -0400
- *Dependencies Scanned:* 80 (52 unique)
- *Vulnerable Dependencies:* 10
- *Vulnerabilities Found:* 71
- *Vulnerabilities Suppressed:* 0
- ...

Analysis Exceptions

- Failed to request component-reports
- Failed to request component-reports
- Failed to request component-reports
- Failed to request component-reports
- Failed to request component-reports
- Failed to request component-reports
- Failed to request component-reports

Summary

Display: Showing Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
log4j-api-2.23.1.jar	cpe:2.3:a:apache:log4j:2.23.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.23.1	MEDIUM	4	Highest	39
spring-boot-3.3.0.jar	cpe:2.3:a:vmware:spring_boot:3.3.0:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot@3.3.0	HIGH	5	Highest	38
spring-boot-starter-thymeleaf-3.3.0.jar	cpe:2.3:a:thymeleaf:thymeleaf:3.3.0:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_boot:3.3.0:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-starter-thymeleaf@3.3.0	HIGH	5	Highest	36
spring-boot-starter-web-3.3.0.jar	cpe:2.3:a:vmware:spring_boot:3.3.0:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:3.3.0:*:*:*:*:*:*:*	pkg:maven/org.springframework.boot/spring-boot-starter-web@3.3.0	HIGH	5	Highest	36
spring-core-6.1.8.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.8:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-core@6.1.8	MEDIUM	6	Highest	41
spring-security-core-6.3.0.jar	cpe:2.3:a:pivotal_software:spring_security:6.3.0:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_security:6.3.0:*:*:*:*:*:*:*	pkg:maven/org.springframework.security/spring-security-core@6.3.0	CRITICAL	4	Highest	38
spring-security-web-6.3.0.jar	cpe:2.3:a:pivotal_software:spring_security:6.3.0:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_security:6.3.0:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:6.3.0:*:*:*:*:*:*:*	pkg:maven/org.springframework.security/spring-security-web@6.3.0	CRITICAL	4	Highest	38
spring-web-6.1.8.jar	cpe:2.3:a:pivotal_software:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:springsource:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:vmware:spring_framework:6.1.8:*:*:*:*:*:*:* cpe:2.3:a:web_project:web:6.1.8:*:*:*:*:*:*:*	pkg:maven/org.springframework/spring-web@6.1.8	MEDIUM	6	Highest	35
thymeleaf-3.1.2.RELEASE.jar	cpe:2.3:a:thymeleaf:thymeleaf:3.1.2:release:*:*:*:*:*	pkg:maven/org.thymeleaf/thymeleaf@3.1.2.RELEASE	CRITICAL	2	Highest	23
tomcat-embed-core-10.1.24.jar	cpe:2.3:a:apache:tomcat:10.1.24:*:*:*:*:*:*:* cpe:2.3:a:apache_tomcat:apache_tomcat:10.1.24:*:*:*:*:*:*:*	pkg:maven/org.apache.tomcat.embed/tomcat-embed-core@10.1.24	CRITICAL*	30	Highest	63

* indicates the dependency has a known exploited vulnerability

Aseguramiento de calidad y cobertura (JACOCO)

Para garantizar la fiabilidad del código y la resiliencia del sistema ante escenarios inesperados, se diseñó una suite de pruebas exhaustivas enfocada en la validación de controladores y en la lógica de seguridad.

Implementación de Pruebas y cobertura de Ramas (Branch Coverage)

Se implementaron estrategias avanzadas de testing para asegurar los flujos críticos de la aplicación.

1. **Controladores:** Se integró la librería MockMvc para testear los puntos de entrada HTTP (AnimalController y AuthController). Esto permitió simular peticiones reales y validar respuestas (ej. 200 OK) de forma aislada sin necesidad de levantar el servidor web
2. **Lógica condicional:** Se diseñaron pruebas específicas para los bloques de decisión (caminos de éxito y error) en la clase CustomUserDetailService. Se validó la carga exitosa de usuarios existentes y el correcto lanzamiento de la excepción UsernameFoundException ante credenciales invalidas.

Configuración de Quality Gates

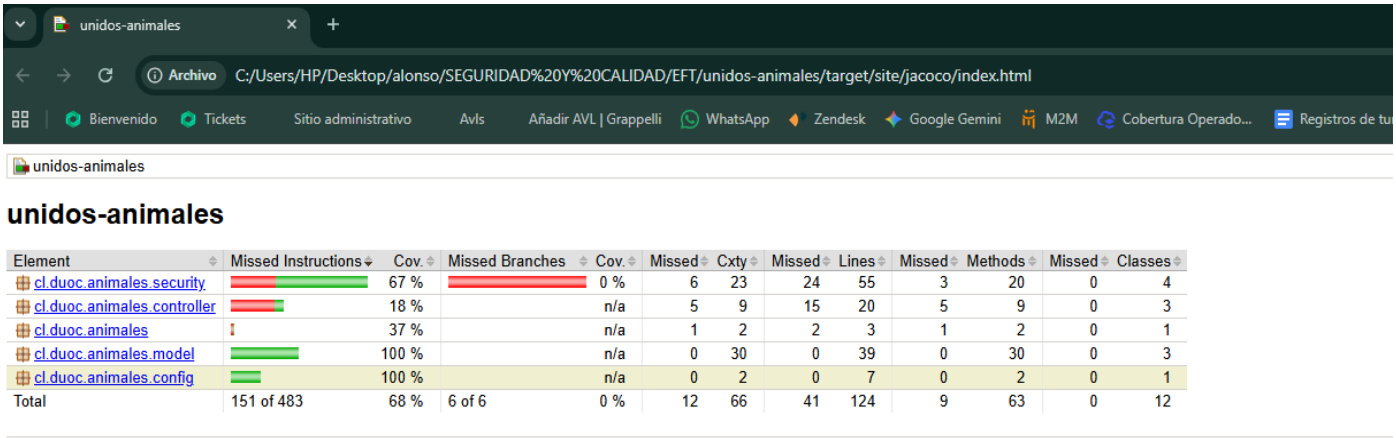
Como medida preventiva, se configuró un Quality Gate directamente en el archivo pom.xml mediante el goal check de JaCoCo. Se estableció un umbral estricto para bloquear cualquier integración de código que reduzca la cobertura por debajo del 60%.

```
<rule>
                                    <element>BUNDLE</element>
                                    <limits>
                                        <limit>
                                            <counter>COMPLEXITY</counter>
                                            <value>COVEREDRATIO</value>
                                            <minimum>0.60</minimum>
                                        </limit>
                                    </limits>
                                </rule>
```

Resultado de la ejecución

La ejecución de las pruebas unitarias finalizó exitosamente sin fallos. El reporte de JaCoCo evidenció una cobertura global del 68%, superando holgadamente el mínimo establecido para este proyecto y logrando una cobertura sobresaliente del 67% en el paquete critico de seguridad.

```
y.web.context.SecurityContextHolderFilter@51e74653, org.springframework.security.web.header.HeaderWriterFilter@21b72dad, org.springframework.web.filter.CorsFilter@27699
6f2, org.springframework.security.web.csrf.CsrfFilter@5fa5dc92, org.springframework.security.web.authentication.logout.LogoutFilter@487d0a60, org.springframework.securi
ty.web.authentication.UsernamePasswordAuthenticationFilter@e66047f, org.springframework.security.web.savedrequest.RequestCacheAwareFilter@a9967f1, org.springframework.s
ecurity.web.servletapi.SecurityContextHolderAwareRequestFilter@2153b10d, org.springframework.security.web.authentication.AnonymousAuthenticationFilter@379f1d78, org.spr
ingframework.security.web.access.ExceptionTranslationFilter@675fd2a9, org.springframework.security.web.access.intercept.AuthorizationFilter@72dd4320]
2026-05-06T22:31:40.795-04:00  INFO 21136 --- [           main] c.d.a.UnidosAnimalesApplicationTests     : Started UnidosAnimalesApplicationTests in 10.284 seconds (pro
cess running for 17.564)
Hibernate: select u1_0.id,u1_0.password,u1_0.role,u1_0.username from users u1_0
Hibernate: insert into users (password,role,username,id) values (?,?,?,default)
Hibernate: insert into users (password,role,username,id) values (?,?,?,default)
Hibernate: insert into users (password,role,username,id) values (?,?,?,default)
✅ ¡Base de datos limpiada y los 3 usuarios fueron creados exitosamente!
[INFO] Tests run: 1, Failures: 0, Errors: 0, Skipped: 0, Time elapsed: 12.29 s -- in cl.duoc.animales.UnidosAnimalesApplicationTests
[INFO]
[INFO] Results:
[INFO]
[INFO] Tests run: 8, Failures: 0, Errors: 0, Skipped: 0
[INFO]
[INFO]
[INFO] --- jacoco:0.8.12:report (default-cli) @ unidos-animales ---
[INFO] Loading execution data file C:\Users\HP\Desktop\alonso\SEGURIDAD Y CALIDAD\EFT\unidos-animales\target\jacoco.exec
[INFO] Analyzed bundle 'unidos-animales' with 12 classes
[INFO] ------------------------------------------------------------------------
[INFO] BUILD SUCCESS
[INFO] ------------------------------------------------------------------------
[INFO] Total time:  26.019 s
[INFO] Finished at: 2026-05-06T22:31:42-04:00
[INFO] ------------------------------------------------------------------------
PS C:\Users\HP\Desktop\alonso\SEGURIDAD Y CALIDAD\EFT\unidos-animales>
```



unidos-animales

Element	Missed Instructions	Cov.	Missed Branches	Cov.	Missed	Cxty	Missed	Lines	Missed	Methods	Missed	Classes
cl.duoc.animales.security		67 %		0 %	6	23	24	55	3	20	0	4
cl.duoc.animales.controller		18 %		n/a	5	9	15	20	5	9	0	3
cl.duoc.animales		37 %		n/a	1	2	2	3	1	2	0	1
cl.duoc.animales.model		100 %		n/a	0	30	0	39	0	30	0	3
cl.duoc.animales.config		100 %		n/a	0	2	0	7	0	2	0	1
Total	151 of 483	68 %	6 of 6	0 %	12	66	41	124	9	63	0	12

Acceso y Validación del sistema

Para la validación funcional por parte del equipo evaluador, se proporcionan las siguientes credenciales y accesos al entorno local:

- **Repositorio de Código fuente:** https://github.com/L0ncho/EFT_SEGURIDAD-CALIDAD.git
- **Servidor Local:** La aplicación se levanta en el puerto predeterminado http://localhost:8080
- **Credenciales de administración:**
  - **Usuario:** admin
  - **Contraseña:** admin123

Conclusión

El desarrollo de la plataforma “Unidos por los Animales” ha cumplido satisfactoriamente con los criterios de evaluación. La integración proactiva de herramientas DAS, SAST, SCA, sumada a una estrategia de pruebas unitarias con simulación de endpoints (MockMvc) y Quality Gates (68% de cobertura), garantiza un producto final resiliente, mantenible y preparado para operar bajo altos estándares de seguridad.

Reservados todos los derechos Fundación Instituto Profesional Duoc UC. No se permite copiar, reproducir, reeditar, descargar, publicar, emitir, difundir, de forma total o parcial la presente obra, ni su incorporación a un sistema informático, ni su transmisión en cualquier forma o por cualquier medio (electrónico, mecánico, fotocopia, grabación u otros) sin autorización previa y por escrito de Fundación Instituto Profesional Duoc UC La infracción de dichos derechos puede constituir un delito contra la propiedad intelectual.